TP sécurisation des applications web

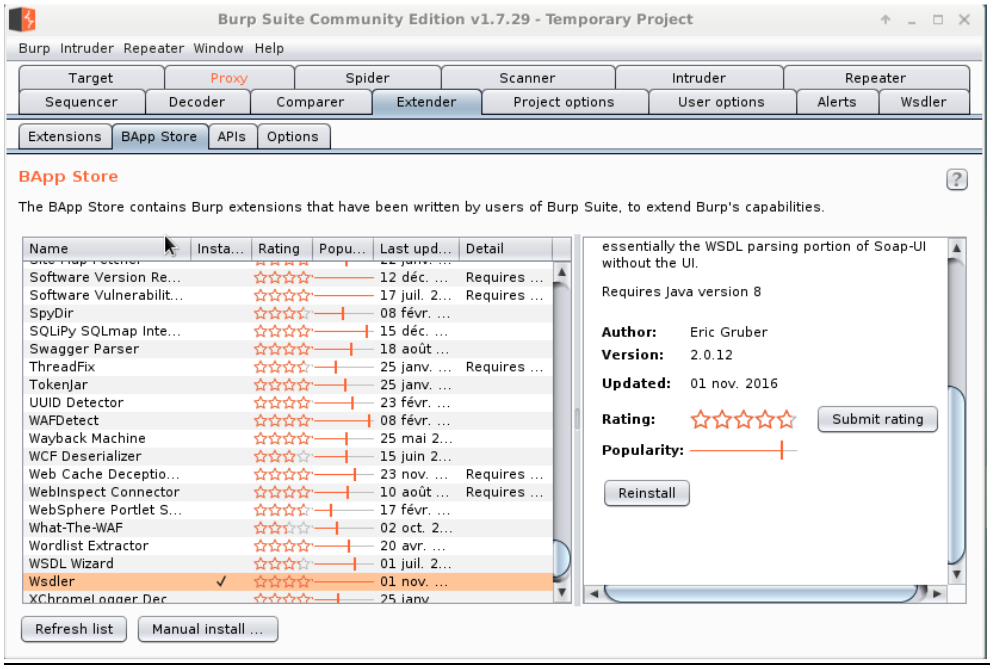
Activité 2: Vulnérabilités liées à l'authentification et à la gestion des sessions

Travail à faire 1 : Enumération des logins en mode non sécurisé

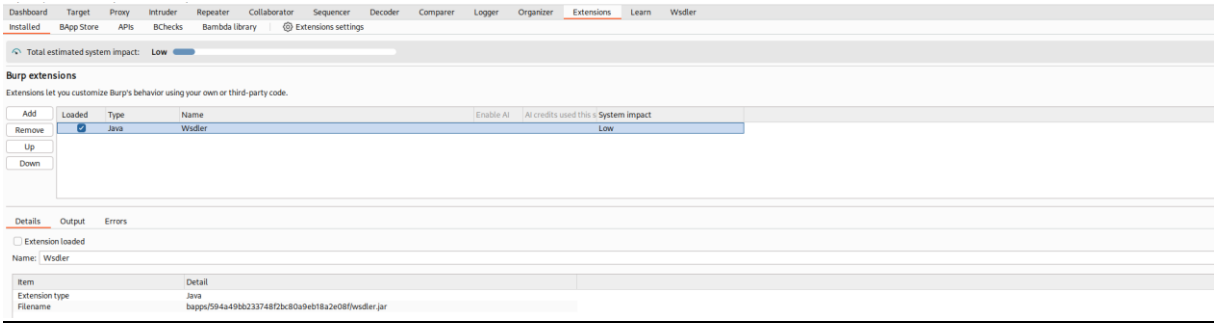
Q1 :

Cette extension permet d'intercepter les requête WSDL ainsi que les opérations liées au service web ciblé. Elle offre la possibilité de générer des requêtes SOAP qui peuvent ensuite être envoyées au service web.

Pour commencer, il faut lancer Burp Suite se rendre dans l'onglet Extender puis dans le Bapp Store. Il suffit ensuite de sélectionner l'extension Wsdler et de l'installer en cliquant sur le bouton installer situé en bas de la fenêtre.



Une fois l'installation terminée, vérifier que l'extension s'affiche dans l'onglet Extensions.



Niveau de sécurité à la position 0

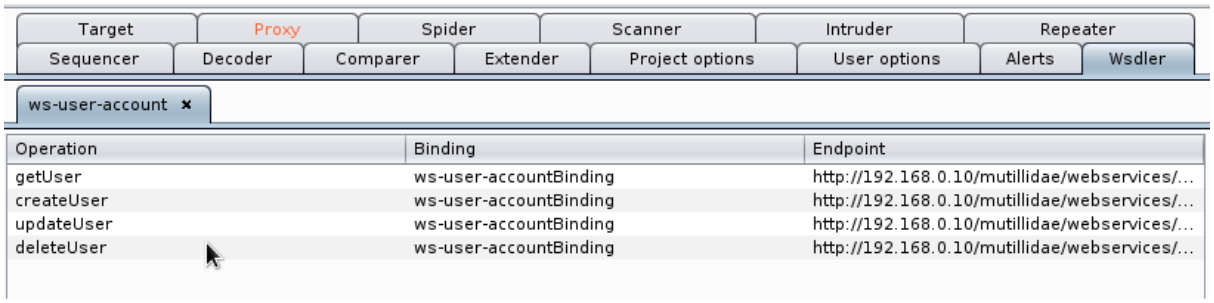
Q2 :

Il faut d'abord régler le proxy sur Intercept off, puis ouvrir la page suivante :

OWASP 2017 -> A2 : Broken Authentication and Session Management -> Username Enumeration -> Lookup User (SOAP Web Service)

Ensuite remettre le proxy sur Intercept on, puis cliquer dans le navigateur sur le lien View the WSDL

Vérifier que l'onglet Wsdler dans Burp Suite affiche bien les différentes opérations disponibles.



Pour l'énumération des utilisateurs, l'opération getUser est celle qui nous intéresse. Il faut cliquer sur getUser et observer le contenu de la requête, en particulier la balise username.
Cette balise contient une valeur par défaut correspondant à un login qui n'existe pas parmi les comptes valides. Cette requête permet donc de tester le comportement de l'application lorsqu'un login inexistant est utilisé.

Operation	Binding	Endpoint
getUser	ws-user-accountBinding	http://192.168.0.10/mutillidae/webservices...
createUser	ws-user-accountBinding	http://192.168.0.10/mutillidae/webservices

Request

Raw | Params | Headers | Hex | XML

```
Accept-Encoding: gzip, deflate
Cookie: PHPSESSID=le6hhbr13m8f8vo66qh9mgg7i5
Connection: close
Upgrade-Insecure-Requests: 1
SOAPAction: urn:ws-user-account#getUser
Content-Type: text/xml;charset=UTF-8
Host: 192.168.0.10
Content-Length: 452

<soapenv:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/"
xmlns:urn="urn:ws-user-account">
   <soapenv:Header/>
   <soapenv:Body>
      <urn:getUser soapenv:encodingStyle="http://schemas.xmlsoap.org/soap/encoding/">
         <username xsi:type="xsd:string">gero et</username>
```

Il faut effectuer un clic droit dans la fenêtre contenant la requête associée à un login inexistant (onglet Raw), puis sélectionner Send to Repeater.
Un nouvel onglet est alors ajouté dans la section Repeater de Burp Suite, correspondant à cette requête.
Dans cet onglet, la partie Request affiche la requête envoyée, tandis que l'onglet Raw montre le flux capturé.
Il suffit ensuite de cliquer sur le bouton Go pour obtenir la réponse du serveur.
Il est alors possible d'observer le message indiquant que l'utilisateur n'existe pas, par exemple *User … does not exist*.

1 × ...

Go Cancel < > Target: http://192.168.0.10

Request

Raw | Params | Headers | Hex | XML

```
POST
/mutillidae/webservices/soap/ws-user-account.php
HTTP/1.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64;
rv:52.0) Gecko/20100101 Firefox/52.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.
9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Cookie: PHPSESSID=le6hhbr13m8f8vo66qh9mgg7i5
Connection: close
Upgrade-Insecure-Requests: 1
SOAPAction: urn:ws-user-account#getUser
Content-Type: text/xml;charset=UTF-8
Host: 192.168.0.10
Content-Length: 452

<soapenv:Envelope
```

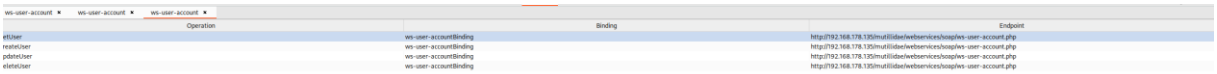
Response

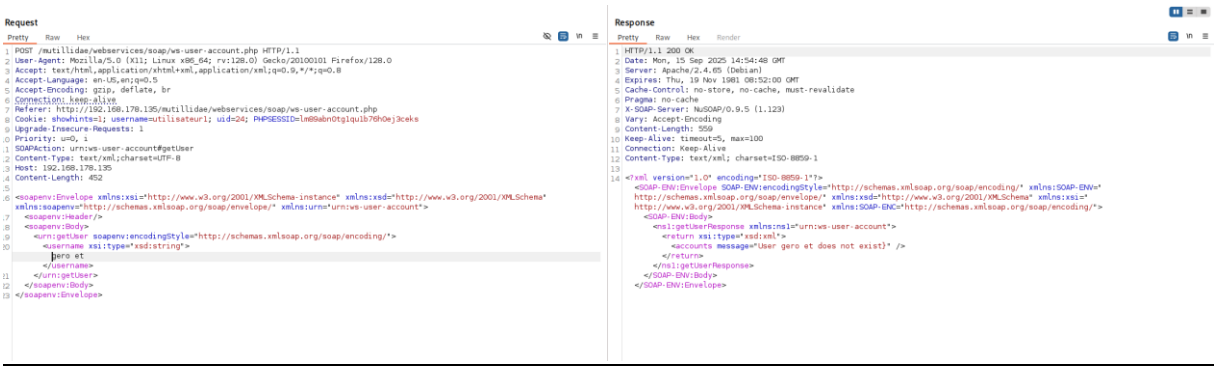
Raw | Headers | Hex | XML

```
Content-Type: text/xml; charset=ISO-8859-1

<?xml version="1.0"
encoding="ISO-8859-1"?><SOAP-ENV:Envelope
SOAP-ENV:encodingStyle="http://schemas.xmlsoap.org/
soap/encoding/"
xmlns:SOAP-ENV="http://schemas.xmlsoap.org/soap/env
elope/"
xmlns:xsd="http://www.w3.org/2001/XMLSchema"
xmlns:xsi="http://www.w3.org/2001/XMLSchema-instanc
e"
xmlns:SOAP-ENC="http://schemas.xmlsoap.org/soap/enc
oding/"><SOAP-ENV:Body><ns1:getUserResponse
xmlns:ns1="urn:ws-user-account"><return
xsi:type="xsd:xml"><accounts message="User gero et
does not exist}"
/></return></ns1:getUserResponse></SOAP-ENV:Body></
SOAP-ENV:Envelope>
```

Il faut effectuer un clic droit dans la fenêtre de la réponse (partie droite), puis sélectionner Send to Comparer.
L'onglet Comparer de Burp Suite ajoute alors cette première réponse, correspondant à un login inexistant.





Q3

Avant de commencer il faut créer un nouvel utilisateur dans Mutillidae nommé utilisateur1, en lui attribuant un mot de passe.

Pour cela il suffit de cliquer sur le lien Please register here présent sur la page d'authentification.

Pour les besoins du TP, un second utilisateur nommé utilisateur2 doit également être crée.

Il faut ensuite refaire les mêmes manipulations que lors de l'étape n°2, mais cette fois avec un login valide.

Pour cela, commencer par mettre le proxy sur Intercept off, puis ouvrir la page :

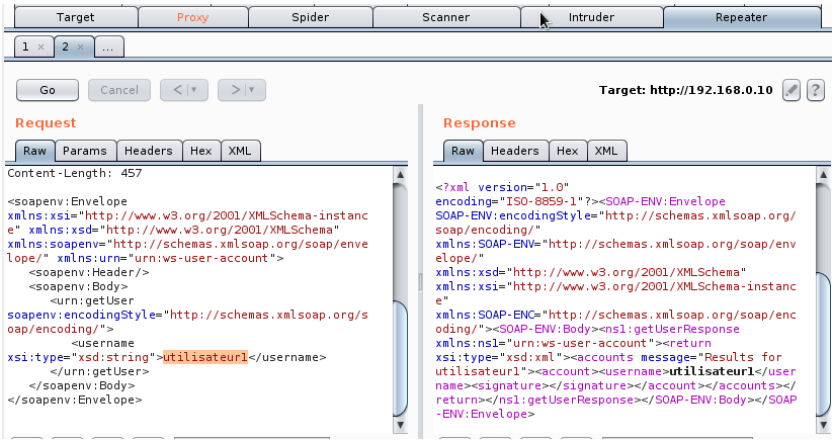
OWASP 2017 → A2 : Broken Authentication and Session Management → Username Enumeration → Lookup User (SOAP Web Service).

Ensuite, remettre le proxy sur Intercept on et cliquer sur le lien View the WSDL.

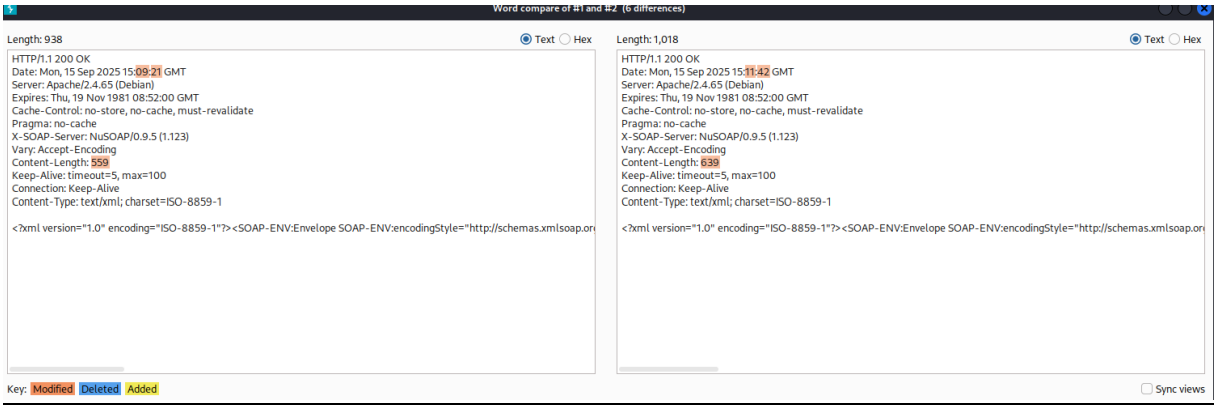
Comme précédemment, effectuer un clic droit dans la fenêtre de capture du proxy et sélectionner Parse WSDL.

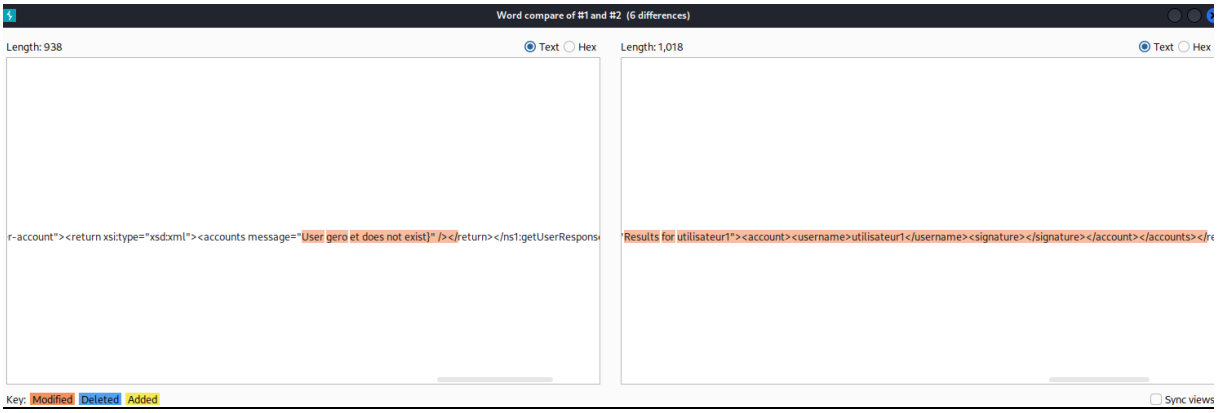
Dans l'onglet Wsdler de Burp Suite, cliquer sur getUser, puis envoyer la requête au Repeater avec un clic droit (Send to Repeater).

Un second onglet apparaît alors dans le Repeater. À ce moment-là, il faut remplacer la valeur du login par un login valide, par exemple utilisateur1.



Il faut ensuite cliquer sur le bouton Go afin d'obtenir la réponse associée à un login valide. On peut alors observer la présence de la chaîne de caractères « Results for ». La réponse peut ensuite être envoyée au Comparer par un clic droit (Send to Comparer).
L'onglet Comparer de Burp Suite permet de comparer les réponses obtenues entre un login valide et un login inexistant. En cliquant sur le bouton Words, il est possible d'identifier les différences.
La fenêtre de gauche correspond à la réponse pour un login inexistant, tandis que celle de droite correspond à un login existant.





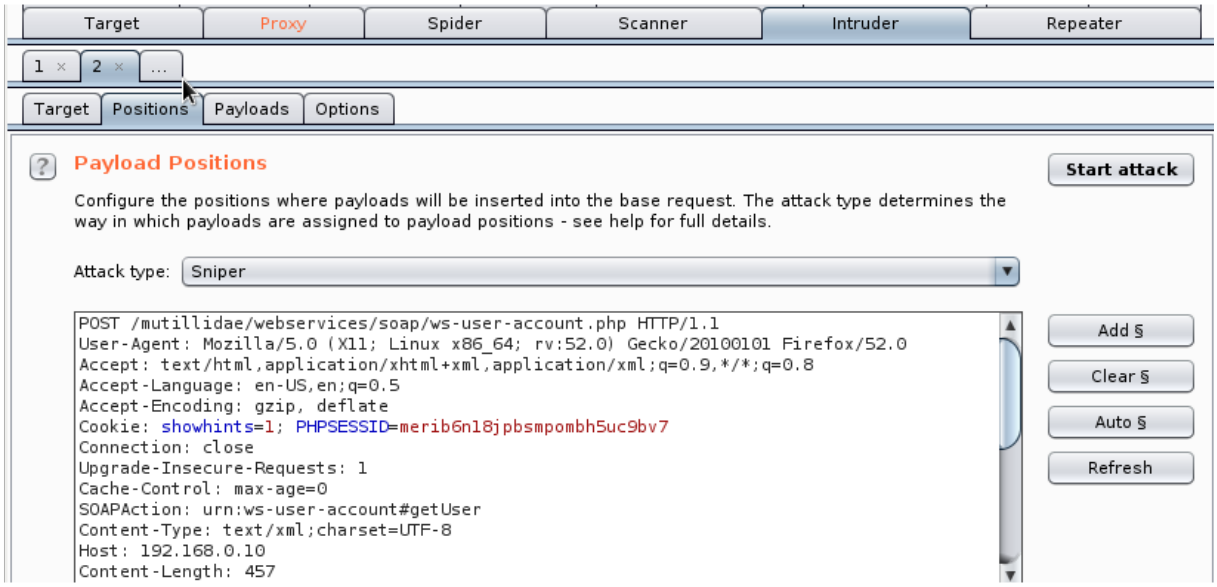
Q4 :

Les étudiants doivent disposer d'un dictionnaire de logins, qu'ils peuvent créer à l'aide de l'éditeur de texte de leur choix (vim, nano, etc.). Les logins doivent être écrits les uns à la suite des autres, chacun sur une ligne différente. Le fichier peut être enregistré dans le répertoire personnel de l'utilisateur sur la machine cliente équipée de Burp Suite.

Q5 :

Il faut retourner dans l'onglet Repeater de Burp Suite et dans la fenetre de réponse correspondant à un login valide (fenêtre de droite), effectuer un clic droit puis sélectionner Send Intruder.

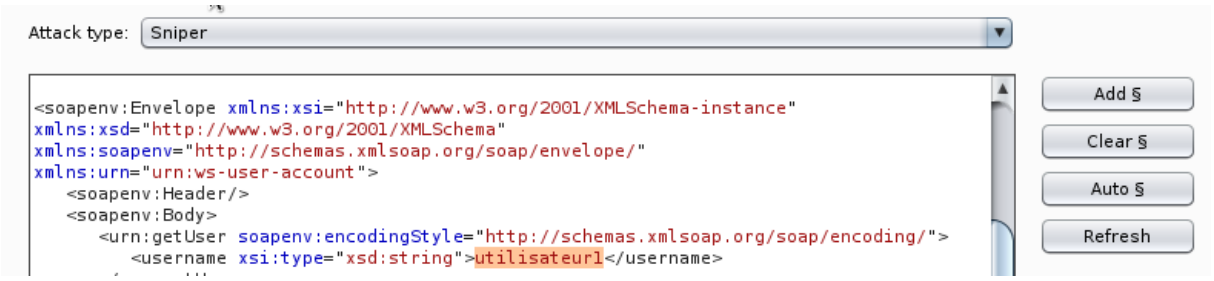
Ensuite se rendre dans l'onglet Intruder cliquer sur l'onglet Positions puis sur le bouton Clear.



Dans cette même fenêtre, il faut sélectionner avec un double clic la valeur correspondant au login (par exemple utilisateur1), puis cliquer sur le bouton Add.

Une seule variable est utilisée, ce qui correspond au mode Sniper. D'autres modes existent et permettent de travailler avec plusieurs variables.

Une fois la valeur définie, Burp Suite pourra tester automatiquement les différentes valeurs de login.



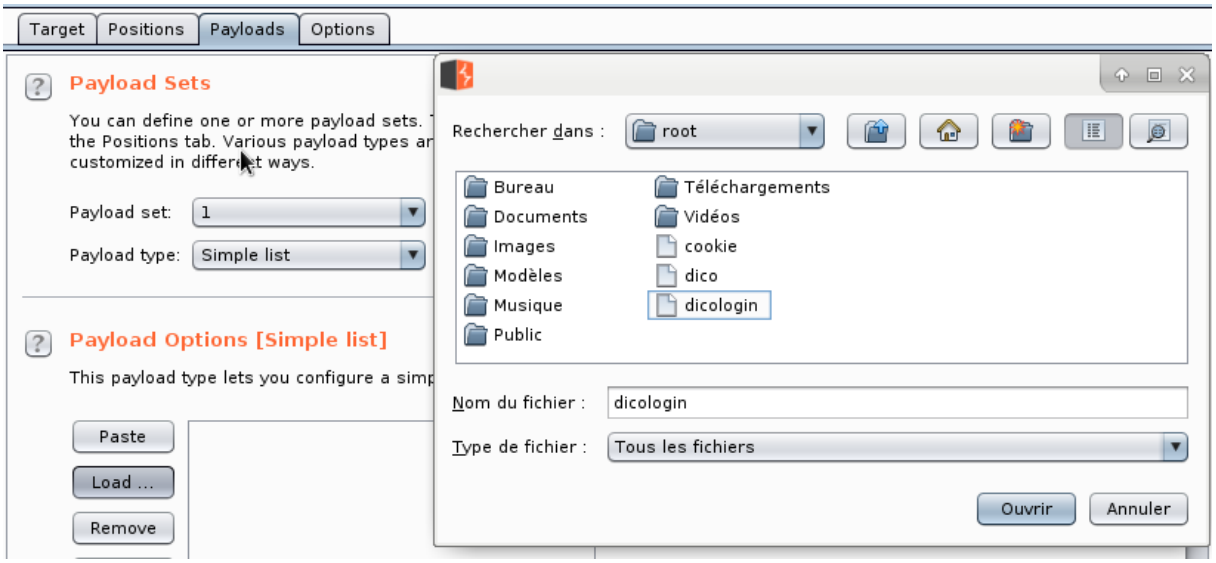
Puis, cliquer sur l' onglet Payload et charger un dictionnaire de login. Ce dictionnaire peut être cree à l'aide d'un editeur de texte comportant une liste de login.

```
  GNU nano 2.7.4                    Fichier : dicologin

utilisateur2
patrice
administrateur
admin
jean
harry
fred
```

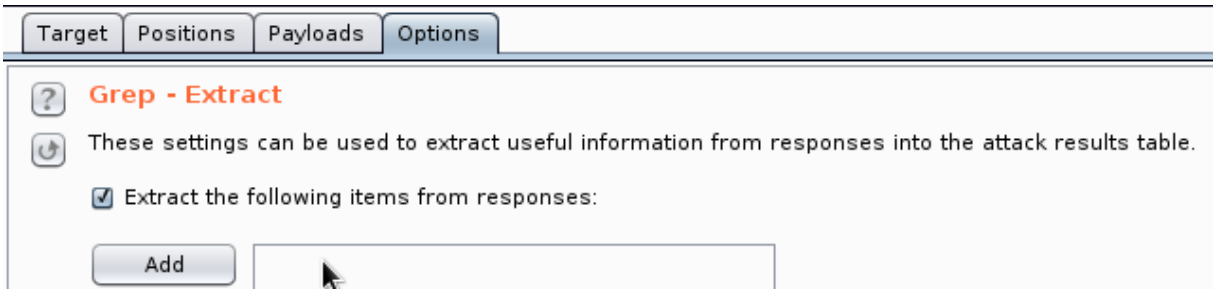
```
root@client-owasp:~# more dicologin
utilisateur2
patrice
administrateur
admin
jean
harry
fred
```

La sélection du dictionnaire se fait en cliquant sur le bouton Load de la rubrique Payload options.

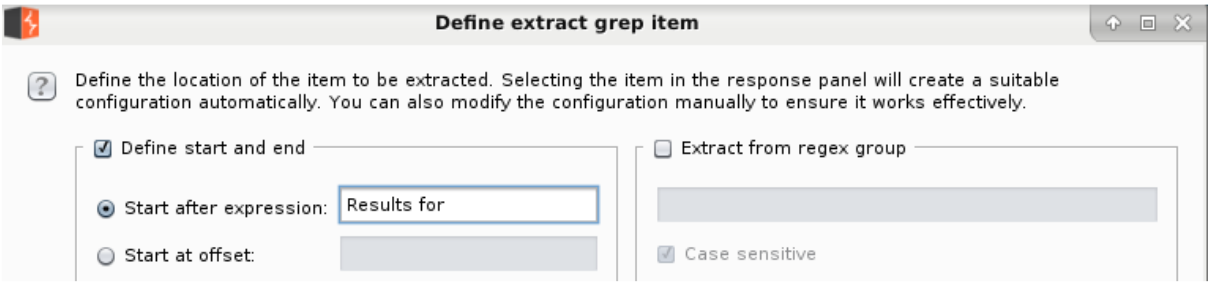


Enfin, dans le dernier onglet Options, il faut ajouter un filtre dans la rubrique Grep Extract. Cliquer

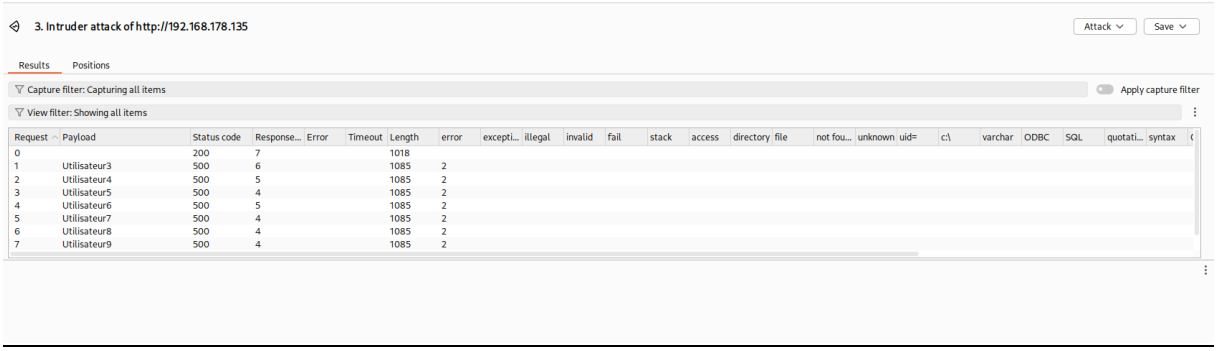
ensuite sur le bouton Add.



Dans la fenetre suivante, il faut indiquer la chaine de caractère correspondant a un login correct: "Results for", puis valider en cliquant sur OK.



Il suffit ensuite de lancer l'attaque en cliquant sur Start Attack dans l'onglet Intruder de Burp Suite.
Le message d'avertissement concernant les limitations de la version *Community* peut être ignoré.
La fenêtre de résultats affichée correspond à l'énumération des logins obtenue lors de l'attaque.



Le login présent sur la première ligne (utilisateur1) correspond à celui utilisé lors du test ayant permis d'obtenir une réponse positive. L'énumération révèle ainsi l'existence de deux autres logins valides : utilisateur2 et admin.

Q6 :

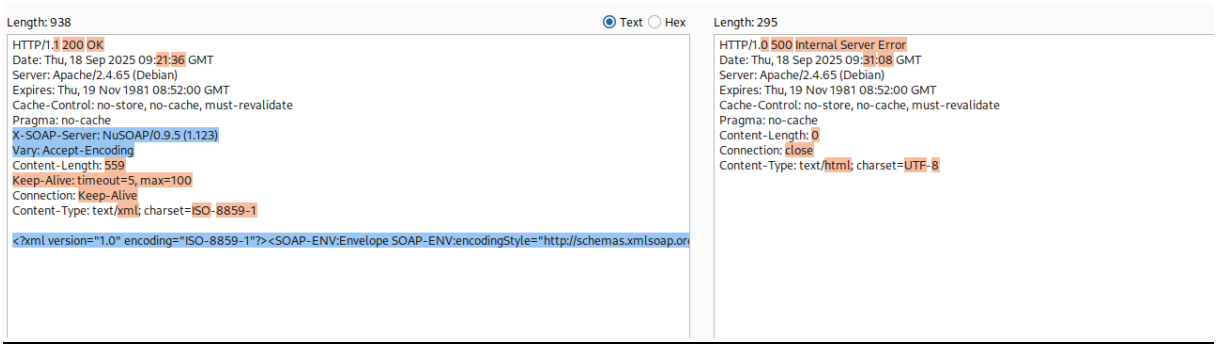
Login incorrect	oding/"><SOAP-ENV:Body><ns1:getUserResponse xmlns:ns1="urn:ws-user-account"><return xsi:type="xsd:xml"><accounts message="User gero et does not exist}" /></return></ns1:getUserResponse></SOAP-ENV:Body></SOAP-ENV:Envelope>
Login correct	xmlns:ns1="urn:ws-user-account"><return xsi:type="xsd:xml"><accounts message="Results for utilisateur1"><account><username>utilisateur1</username><signature></signature></account></accounts></

La chaîne de caractères « Results for » a été utilisée comme filtre lors du lancement de l'attaque. En cas d'échec, un message différent est affiché.

Travail à faire 2 : Enumération des logins en mode sécurisé et analyse du code source

Q1 :

Q2 :



Oui les informations affichées par le comparateur sont exploitables. Un attaquant pourrait détecter si un login existe ou pas. C'est la différence avec 200 et 500 qui permet de savoir si un utilisateur existe.

Q3 :

Dans le fichier ws-user-account.php, la fonction EncodeForHTML est utilisée pour sécuriser les données affichées. Elle transforme les caractères spéciaux en code HTML, par exemple < devient <. Cela empêche qu'un utilisateur mette du code dangereux (HTML ou JavaScript) et rend plus difficile de deviner des logins grâce aux messages affichés.

Travail à faire 3 : Force brute d'un mot de passe

Q1 :

Une attaque par force brute consiste à tester automatiquement une liste de mots de passe à partir d'un dictionnaire. Burp Suite envoie ces mots de passe un par un et analyse les réponses du serveur afin de détecter une authentification réussie.

Pour commencer, il faut lancer Burp Suite et régler Mutillidae sur le niveau de sécurité 0. Le proxy doit être placé en mode Intercept off.

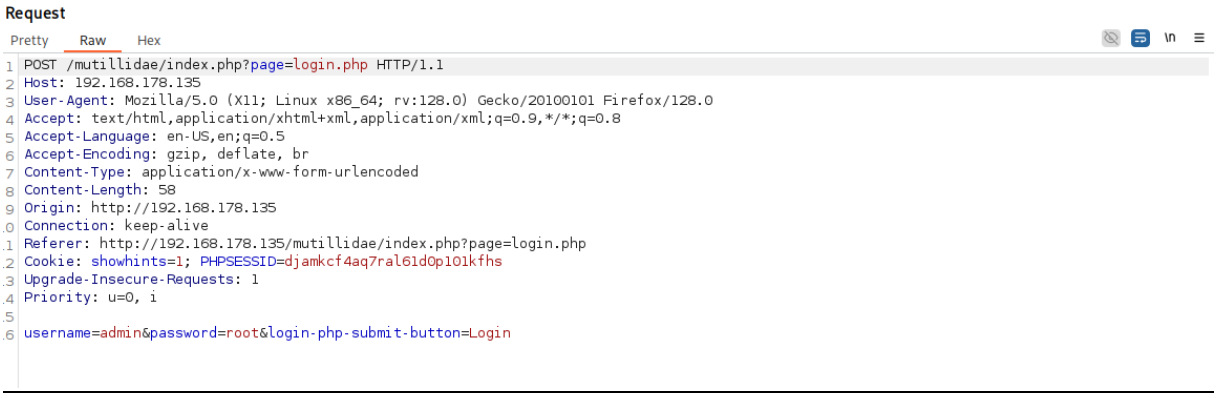
Ensuite, ouvrir la page d'authentification suivante :

OWASP 2017 → A2 (Broken Authentication and Session Management) → Authentication Bypass → Via Brute Force → Login.

Dans cet exemple, le test est réalisé sur un compte dont le login est admin. Dans la version 2.6.62 de Mutillidae, ce compte existe déjà avec le mot de passe adminpass. Les mêmes manipulations peuvent être effectuées sur n'importe quel autre compte existant.

Il faut ensuite activer le proxy (Intercept on). Dans le champ login, saisir admin, puis entrer un mot de passe volontairement incorrect dans le champ mot de passe, avant de cliquer sur Login. Cette étape sert uniquement à préparer la requête pour la suite de l'attaque.

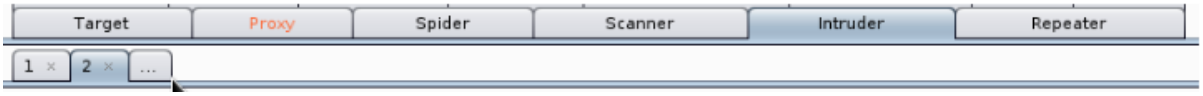
Il faut ensuite cliquer sur le bouton Forward. Dans l'exemple présenté, le mot de passe admin a été saisi, mais cela n'a pas d'importance, car ce mot de passe sera ensuite remplacé par une variable de test utilisée pour l'attaque par force brute.



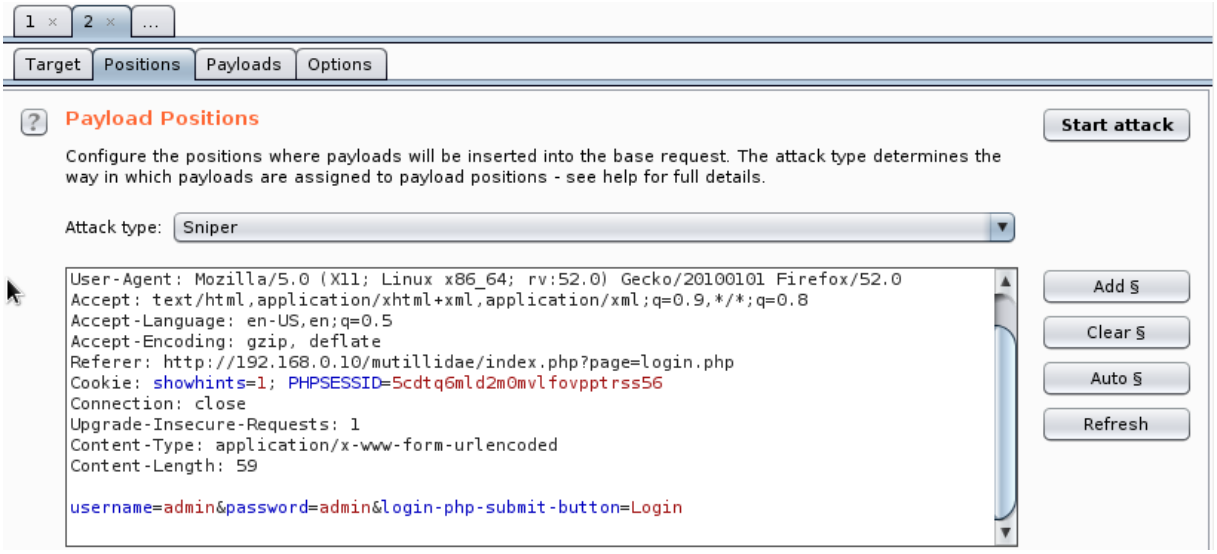
Q2 :

Faire ensuite un clic droit à l'intérieur de cette fenetre et cliquer sur Send to Intruder.

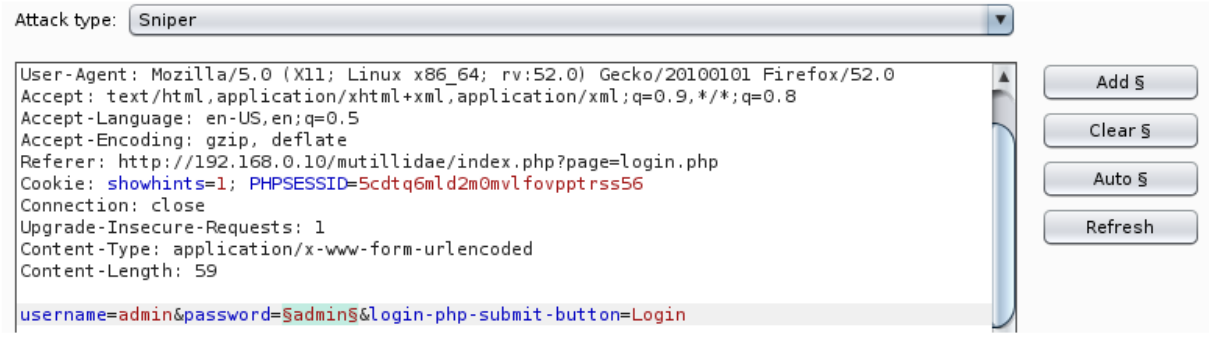
L'onglet Intruder de BurpSuite s'enrichit d'un sous onglet supplémentaire.



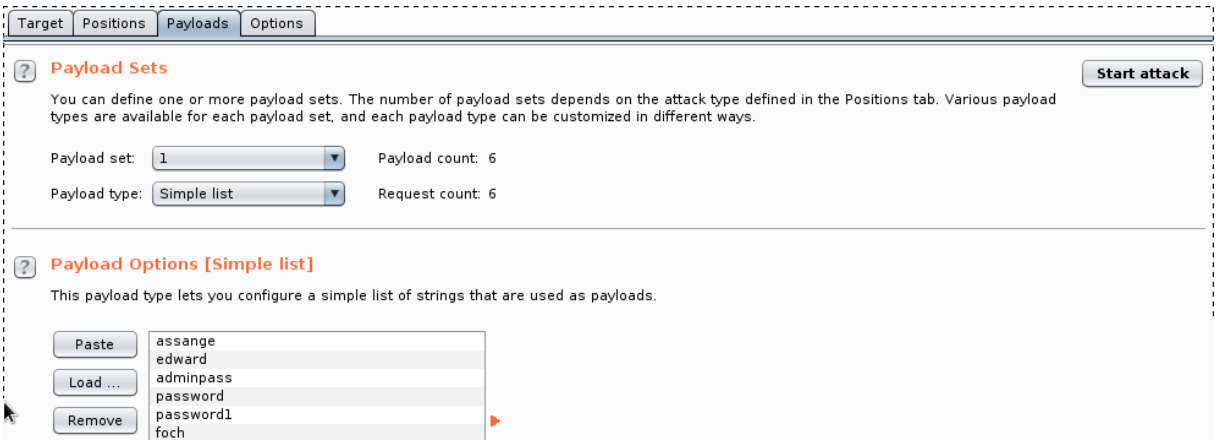
Cliquer sur l'onglet Positions puis sur le bouton Clear.



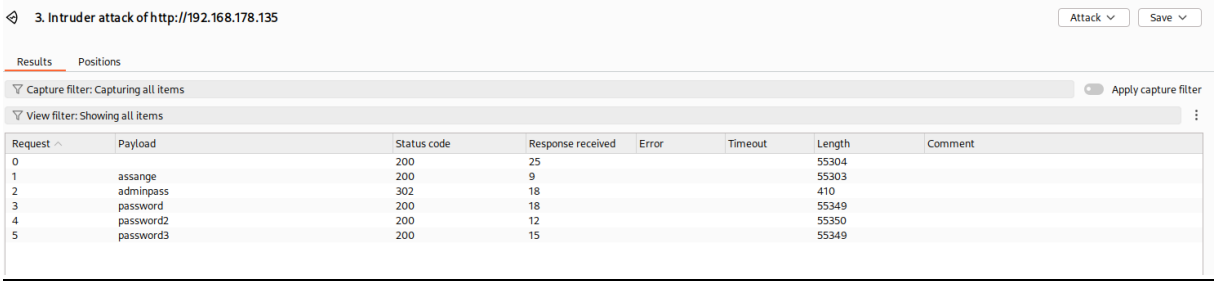
Puis, sélectionner par un double clic le mot de passe saisi (admin) et cliquer sur le bouton Add.



Ensuite, aller dans l'onglet Payload et importer un dictionnaire en cliquant sur le bouton Load dans la partie Payload Options. Le dictionnaire doit avoir été créé au préalable.



Le lancement de l'attaque se fait en cliquant sur le bouton Start Attack.



Travail à faire 4 : Codage sécurisé et analyse du code source

Q1 :

La force brute n'a pas échoué car on peut voir qu'avec adminpass il renvoie 302. C'est pareil quand la sécurité été au niveau 0.

2. Intruder attack of http://192.168.178.135

Attack Save

Results Positions

Capture filter: Capturing all items

Apply capture filter

View filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
0		200	20			50220	
1	assange	200	17			50219	
2	adminpass	302	12			430	
3	password	200	15			50270	
4	password2	200	20			50271	
5	password3	200	16			50270	

Q2 :

Rien n'empêche un utilisateur de choisir un mot de passe faible (par exemple *password* ou *admin7*). Le niveau de sécurité 5 de cette page ajoute des protections contre d'autres attaques comme les scripts ou les injections SQL.
Pour réduire ce risque, le développeur doit empêcher l'utilisation de mots de passe non sécurisés en mettant en place des mécanismes qui :

- vérifient la solidité du mot de passe lors de la saisie et indiquent s'il est sûr ou non, avec un message explicatif ;
- bloquent la création de comptes utilisant des mots de passe trop simples ou faibles.

Q3 :

Côté administrateur, on peut détecter et contrer ce type d'attaque en limitant le nombre de tentatives de connexion, en enregistrant les tentatives échouées, et en bloquant ou ralentissant les connexions suspectes. Cela empêche la force brute de réussir.

Travail à faire 5 : Vol de session

Q1 :

Pour commencer, se déconnecter de Mutillidae et mettre le proxy en mode non interception en cliquant sur Intercept off. Redémarrer ensuite le navigateur.

Lancer BurpSuite et régler le niveau de sécurité de Mutillidae sur 0, puis accéder à la page suivante :

OWASP 2017 → A2 : Broken Authentication and Session Management → Privilege Escalation → Login.

Entrer ensuite un identifiant et un mot de passe valides correspondant au compte à tester

Cliquer sur le bouton Forward du proxy et observer les cookies captures dans l'onglet Params de l'intercepteur.

L'un des cookies interceptés s'appelle uid et ressemble à un identifiant unique. On peut alors se poser la question du comportement de l'application si l'on renvoie la requête avec une valeur différente. Par exemple, si le dernier numéro est 24, on peut supposer que l'utilisateur suivant correspond au numéro 25. De la même façon, on peut se demander à quel utilisateur est lié le numéro 1.

Q2 :

Modifier la valeur du cookie uid en mettant la valeur 1. Pour cela, double cliquer sur la valeur du cookie et saisir la nouvelle valeur.

GET request to /mutillidae/index.php

Type	Name	Value
URL	page	home.php
URL	popUpNotificationCode	HPH0
Cookie	showhints	1
Cookie	username	utilisateur1
Cookie	uid	1
Cookie	PHPSESSID	5cdtq6mld2m0mvlfovpptrss56

Puis cliquer sur le bouton Forward du proxy. On se retrouve connecte en tant qu' administrateur.

Travail à faire 6 : Codage sécurisé et analyse du code source

Q1 :

Oui, elle a une conséquence : nous sommes restés en tant qu'utilisateur 1 et non en admin. Le fait d'être passé en sécurité 5 bloque aussi.

Q2 :

Au niveau de sécurité 5, la page d'accueil est codée de façon plus sûre que dans les niveaux 0 et 1. Les données affichées sont encodées pour éviter les failles (par exemple avec EncodeForHTML), les sessions sont mieux protégées et les cookies ont des options de sécurité. Les messages d'erreur sont aussi plus neutres et ne donnent plus d'informations utiles à un attaquant.

Q3 :

Un cookie est un petit fichier stocké dans le navigateur de l'utilisateur, il peut contenir un identifiant ou quelques données.

Une session garde les informations côté serveur et utilise seulement un identifiant dans le cookie pour retrouver ces données.

Bonnes pratiques : ne pas mettre d'informations sensibles directement dans le cookie, utiliser des identifiants de session longs et imprévisibles, activer les options de sécurité (HttpOnly, Secure) et régénérer l'identifiant de session après la connexion.